

API Security Risk Assessment Report

1. Executive Summary

This report presents a security assessment of a publicly available API. The objective is to evaluate its security posture by analyzing authentication mechanisms, data exposure, and access control. The findings indicate that while the API is suitable for testing and educational purposes, it lacks essential security controls required for production environments.

2. API Endpoint Under Review

- **API URL:** <https://jsonplaceholder.typicode.com/posts>
 - **Method:** GET
 - **Type:** Public REST API
-

3. Tools & Environment

- Web Browser (Google Chrome / Microsoft Edge)
 - Browser Developer Tools (for response inspection)
 - Manual analysis of JSON response structure
-

4. Security Analysis Findings

◆ 4.1 Authentication

The API does not implement any authentication mechanism. No API keys, tokens, or login credentials are required to access the endpoint.

 **Observation:** Fully open access

◆ 4.2 Data Exposure

The API returns structured JSON data containing:

- userId
- id
- title
- body

All records are publicly accessible without restrictions or filtering.

➡ **Observation:** Unrestricted data exposure

◆ 4.3 Access Control & Rate Limiting

No access control policies or rate-limiting mechanisms were observed. The API can be accessed repeatedly without limitation.

➡ **Observation:** No request throttling or usage control

5. Security Risks Identified

5.1 Unauthorized Access Risk

The absence of authentication allows any user to access the API without verification, increasing the risk of misuse in real-world applications.

5.2 Data Exposure Risk

Sensitive data could be exposed if similar architecture is used in production systems without proper filtering or authorization.

5.3 Denial of Service (DoS) Risk

Lack of rate limiting allows unlimited requests, which could lead to system overload or abuse.

6. Recommendations

- Implement authentication mechanisms (e.g., API keys, OAuth2, JWT)
 - Enforce role-based access control (RBAC)
 - Introduce rate limiting and request throttling
 - Apply input validation and response filtering
 - Monitor API usage through logging and analytics
-

7. Conclusion

The analyzed API is designed for testing and educational purposes and therefore does not include production-level security controls. However, in a real-world scenario, the absence of authentication, access control, and rate limiting represents significant security vulnerabilities that must be addressed before deployment.

This assessment demonstrates basic API security analysis skills including risk identification, classification, and remediation planning aligned with common cybersecurity best practices.